Electronic Health Record (EHR) Protection, Resilience and Recovery

Francisco Acosta

Contingency Plan

April 26, 2025

INTRODUCTION

1.1 PURPOSE

Sector: Healthcare

The Electronic Health Record (EHR) Protection, Resilience, and Recovery Contingency Plan establishes formal procedures to protect and restore data, as well as resume operations following a cyberattack or similar incident.

Description of System:
This Electronic Health Record (EHR) system stores electronic protected health information (ePHI), which consists of patient medical history, social security numbers, medications, diagnosis information, lab results, immunizations, medical notes, and imaging for a network of medical providers and hospitals.
The EHR system gives healthcare professionals the ability to ingest and retrieve ePHI from a secure centralized location. This access of ePHI creates a streamlined process in which patients and providers can safely interact with one another.

Problem:
Electronic Health Record (EHR) systems are increasingly targeted by cyberattacks, placing electronic Protected Health Information (ePHI) at significant risk. Without a well-structured contingency plan, the EHR system faces potential data breaches, service outages, and widespread operational disruptions.

Justification:
Protecting ePHI is not only a legal obligation under the Health Insurance Portability and Accountability Act (HIPAA), but also a strategic priority. Failure to do so can lead to substantial financial penalties, litigation, and reputational harm.
A well-defined contingency plan supports compliance, fosters proactive risk management, strengthens long-term strategic planning, and reinforces a culture of privacy and security which safeguards patient trust and the EHR system's resilience.

Solution:
This plan outlines remediation strategies and comprehensive security protocols to protect ePHI throughout its lifecycle. Clear policies are established for the secure handling of sensitive data to ensure operational continuity in the event of cyber incidents or system failures. These measures enhance the EHR system's security posture and improve incident response capabilities.
Guarding ePHI requires data access control to limit exposure, encryption to ensure data integrity, incident response procedures to manage security threats, data recovery standard operational procedures to ensure authorized access remains available, audit logs for forensics, data minimization to limit exposure, network segmentation to prevent unauthorized access, and continuous monitoring to search for anomalies in the event of a data breach.

Expectations of accomplishment:
The goal is to restrict access to ePHI until the vulnerability is fully remediated, while preserving data integrity and accessibility, as well as ensuring a rapid response to address any potential impact.

Business reasons for addressing the problem:
This contingency plan is developed in alignment with the recommendations of the Health Insurance Portability and Accountability Act (HIPAA), which require the establishment and implementation of formal procedures to respond to events that compromise systems housing electronic protected health information. Providing data security is the top priority, as it protects patients from potential harm and shields the healthcare network from legal and financial liabilities.

1.2 SCOPE

1.2.1 Planning

Various scenarios were considered to form a basis for this plan, and multiple assumptions were made. The applicability of the plan is predicated on the following business needs.

- Establishing a risk management framework to identify potential threats and define standard operational procedures that strengthen the EHR system's overall security posture.
- Implementing proactive safeguards to ensure confidentiality, integrity, and availability of electronic Protected Health Information (ePHI).
- Maintaining compliance with state and federal regulations.
- Ensuring audit readiness to support continuous regulatory compliance and operational resilience.
- Mitigating threats to effectively reduce the impact of cyberattacks and proactively prepare for future threats.
- Deploying robust business continuity measures to maintain critical operations during and after cybersecurity incidents.
- Developing comprehensive incident response policies to enable efficient recovery, minimize downtime, and apply lessons learned to future safeguards.

Recommended Privacy Strategies for Safeguarding Health Information

- Protect patient privacy by implementing strong encryption protocols for both data at rest and in transit.
- Employ data minimization and anonymization techniques to reduce the volume and sensitivity of exposed data in the event of a breach.
- Enforce strict data retention policies that align with legal and regulatory requirements to avoid prolonged and unnecessary storage of ePHI.
- Provide ongoing employee education and training to reinforce privacy best practices, ensuring appropriate handling of sensitive information, especially during system failures and security incidents.
- Clearly define and enforce policies covering user authentication, access restrictions, breach response procedures, and the secure management of ePHI throughout its lifecycle.

Together, these strategies support HIPAA Privacy Rule compliance by demonstrating a strong commitment to protecting patient data while maintaining trust.

Recommended Security Strategies for Health Information
The Electronic Health Record (EHR) Prevention, Resilience and Recovery Contingency Plan safeguards the confidentiality, integrity, and availability of electronic protected health information (ePHI) through a layered approach that combines technical, administrative, and physical controls with:

- The principle of least privilege and access restrictions such as role-based access controls (RBAC) to detect and prevent unauthorized access.
- Implementation of multi-factor authentication (MFA) and enforcement of strong password policies with mandatory quarterly updates.
- Establishing redundant systems and backups to ensure minimal downtime, as well as accurate data restoration.
- Isolation of affected systems to prevent further spread of threats through network segmentation.
- The inclusion of CIA Triad (Confidentiality, Integrity, Availability) principles in system architecture and recovery processes.
- Threat Detection & Response
- Security cameras and badge access for server rooms containing ePHI.

- A clearly defined incident response plan, including procedures to:
    - Assess damage.
    - Gather and preserve forensic information.
    - Notify affected parties.
    - Implement fixes.
    - Address long-term solutions, and integrate them into Standard Operational Procedures (SOPs)
- System Hardening & Prevention
- Regular patching.
- Encryption for data at rest and transit
- Deployment of endpoint detection and network monitoring tools for real-time threat analysis.
- Continuous employee training to foster a security-conscious workforce.
- The simulation of real-world scenarios to assess and improve staff response to incidents.
- Periodic audits.

Impact of Policy on Health Information

The effectiveness of this contingency plan is directly influenced by adherence to key federal regulations that shape security and privacy policies in the healthcare sector.

Health Insurance Portability and Accountability Act (HIPAA) Compliance:
HIPAA mandates the implementation of administrative, technical, and physical safeguards to protect ePHI. Policies must align with HIPAA's Security and Privacy Rules, particularly in the following areas:

- Access control and authentication.
- Data Encryption.
- Employee training and awareness.
- Incident detection and response.

- Data retention and disposal.
- Risk Assessment.
- Notification of affected parties of any breaches.

These policies form the regulatory backbone of the EHR system's data protection strategy. They also influence technical implementations, operational procedures, and the overall culture of security and compliance.

1.2.2 Assumptions

Based on these business needs, the following assumptions were used when developing the IT Contingency Plan.

- Spyware has stolen data from the Electronic Health Record (EHR) system.
- A virus or worm has stolen or corrupted data.
- An employee reveals sensitive data by falling victim to Phishing.
- A brute force attack gives unauthorized access to the EHR system.
- A SQL injection attack gives unauthorized access to the EHR system.
- A Denial of Service (DoS) attack causes the EHR system to become inoperable, which results in loss of data and corruption.
- A zero-day exploit takes advantage of a software security flaw and gives unauthorized access to the EHR system.
- A man-in-the-middle attack intercepts data.
- Unintentional workforce careless acts or errors expose data.
- Unintentional or intentional workforce disclosure or destruction of data.
- Intentional workforce computer misuse exposes data.
- Installation of a rogue device or sniffer exposes data.
- Programming errors, software failures or bugs exposing data.
- Theft of hardware that exposes data.
- Hardware or mechanical failure causing loss of data or corruption.

- Ransomware attacks that cause loss of data or corruption.

2 CONCEPT AND OPERATIONS

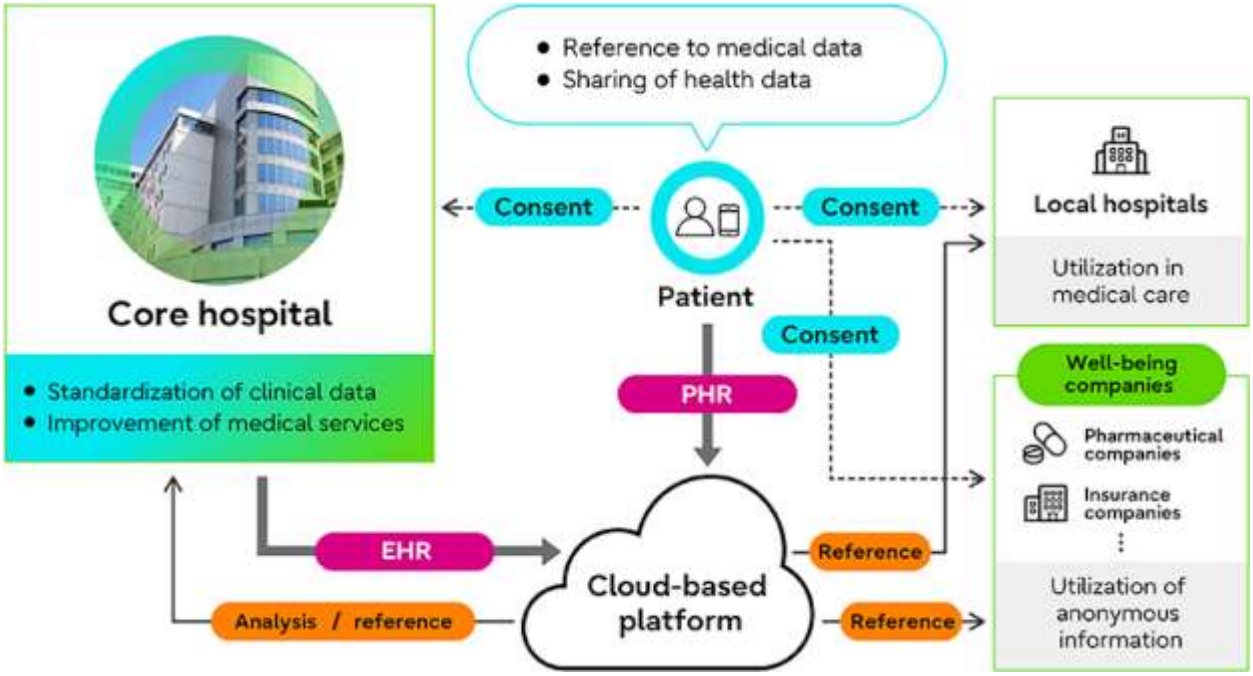
2.1 SYSTEM DESCRIPTION AND ARCHITECTURE

Medical facilities are connected to an internal network which accesses a cloud platform that houses the EHR system. Patients and healthcare professionals are given permission via Role-Based Access Control (RBAC) to view and update data as needed via the EHR system.

Medical facilities connect to the internet via wired and wireless networks separated into different networks. The organization's network is separated via network segmentation and branches into different subnetworks for each facility. Patient wireless networks are managed by each individual facility and live outside of the organization's internal network.

A separate network is created for the cloud based EHR system and extremely sensitive data is stored on an additional air gapped network disconnected from any internet access. The EHR system lives in the cloud on an IBM zOS mainframe to create an extremely secure and stable architecture with high volume capability. The custom nature of the mainframe gives added security and limits outside access.

Healthcare facilities will run on the Windows operating system to accommodate user comfort and will communicate to the EHR system on the cloud mainframe. Creating a Windows based front-end with a back-end system built on a mainframe creates a secure, efficient, and scalable infrastructure.



Ang, A. (2023)

2.2 DESCRIBE THE PLAN

The Cloud-Based Electronic Health Records System will deploy the EHR application on a mainframe which processes and stores all ePHI with automated backups and restoration services for outages. An API gateway will establish communication between the cloud-based mainframe and the facilities Windows environment via a VPN to safeguard data in transit. The gateway will enforce encryption, log activity for audits, utilize Multi-Factor Authentication (MFA), and data access controls such as Role-Based Access Control (RBAC). Continuous Monitoring will take place on the API gateway, cloud mainframe, Windows environment, and VPN.

2.5. DESCRIBE THE TESTING PROCEDURE FOR THE PLAN

Security Testing

Quarterly security testing will be conducted by the internal cybersecurity team and external audits will be performed by third-party professionals on an annual basis. These tests will assess critical areas which include:

- Role-Based Access Control (RBAC)
- API activity logs
- Unauthorized access attempts
- Session timeouts
- Multi-Factor Authentication (MFA)
- Data Encryption
- Penetration testing
- Third Party Access Controls
- Firewall and Port Scanning
- Backup Integrity Checks
- Patch Management
- Password Policy Enforcement
- Quarterly security exercises such as phishing simulations

A successful security test is defined by the following outcomes:

- No unauthorized access is granted.
- Users can only access data relevant to their role.
- All logs accurately reflect user roles and permissions.
- Failed login attempts trigger appropriate alerts.
- User accounts are locked after a set number of failed attempts.
- Passwords must meet length and complexity standards, as well as expire after a designated time.
- Sessions automatically log out after inactivity, prompting users to re-authenticate.
- MFA cannot be bypassed.
- Data is encrypted in transit and at rest.
- Encrypted data cannot be read without an encryption key.
- All critical events are logged with accurate timestamps and user actions.
- Identified risks are patched.
- Access is removed after user deactivation.
- Vendors cannot access approved data.
- Only required ports are open.
- Backups can be restored without error.
- No data loss or corruption in restored files
- Employees are not deceived by simulated phishing attempts.

Compliance Checks
Annual HIPAA compliance reviews will be conducted by the internal compliance officer or privacy team, supplemented by yearly external audits. Additional compliance checks will also take place following major policy changes.

Audits will verify:

- Proper patient consent management.
- Implementation of encryption both at rest and in transit.
- Adherence to data retention policies.
- Effective data anonymization and minimization practices.

Compliance checks will be deemed successful when:

- Patient consent is validated and appropriately documented.
- Data is encrypted in accordance with regulatory standards.
- Stored data adheres to retention timelines.
- ePHI (electronic Protected Health Information) is accessed only when necessary.
- ePHI contains only required information while protecting sensitive details.
- No evidence of data leaks is found in system logs.

Disaster Recovery & Backup Testing
The local IT team will conduct annual audits of disaster recovery policies and procedures to ensure they remain effective and compliant. In addition, monthly reviews are performed on cloud snapshot restoration points to verify data availability and integrity.
Simulated cloud mainframe outages are carried out to test system resilience. During these tests, backup systems are activated to assess whether they are properly configured and capable of restoring services without error.

Success Criteria:

- No data loss or corruption during restoration.
- Minimal service interruption.
- No critical errors during recovery.
- Recovery time objectives (RTO) met or exceeded standards.

Network & Connectivity Tests

Network administrators perform monthly audits to assess firewall configurations, user access controls, and potential vulnerabilities to help ensure the system remains secure with the prevention of unauthorized access.

Quarterly performance audits will evaluate the cloud mainframe's connectivity, including VPN tunnel stability, packet loss, and response times.

Success Criteria:

- Low latency and consistent network throughput.
- No breaches or unauthorized access detected.
- VPN connections remain stable under load.
- Packet loss is within acceptable thresholds.

Generalized Testing Overview

Test results from security, compliance, disaster recovery, backup validation, and network performance are compiled and evaluated.

Success Criteria:

- All individual tests meet or exceed acceptable thresholds.
- Combined results align with standards set by IT leadership, data officers, and the cybersecurity team.
- No critical failures or unresolved vulnerabilities across systems.

2.6. TECHNOLOGY MANAGEMENT AND BUSINESS OBJECTIVE SUPPORT

Data Protection
Implementation of encryption at rest and in transit ensures data integrity.
Data loss and corruption will be combatted with backup automation.

Operational Continuity
Service disruptions are minimized by the establishment of redundant systems, regular disaster recovery tests, data encryption, access controls and incident response procedures.

U.S. Regulatory Compliance
Electronic protected health information (ePHI) is governed by HIPAA to protect patient privacy and ensure data security. The HIPAA privacy rule ensures the protection of ePHI through federal regulations. The HIPAA security rule implements safeguards to protect ePHI by holding medical organizations and their third-party vendors accountable for security compliance. This contingency plan maintains HIPAA compliance through:

- Access controls
- Encryption at rest and in transit
- Data minimization
- Data anonymization
- Data retention policies
- Employee education and training
- Clearly defined policies
- Incident response procedures
- Implementation of Business Associate Agreements (BAA) to ensure the confidentiality, integrity, and availability of ePHI with the use of third-party vendors such as:
    - Cloud providers
    - Backup service providers
    - Security auditors
    - Access control vendors

Audit readiness and employee training
Ongoing employee education and training provides privacy best practices to ensure the appropriate handling of sensitive data to keep staff informed of policies and procedures. Education and training consist of:

- Simulation of attacks such as phishing and data breaches to reinforce situational awareness.
- Establishment of incident response procedures.
- Annual courses to reaffirm HIPAA compliance and proper patient consent management.

2.7. DESIGN, IMPLEMENTATION, AND EVALUATATION

Design and Implementation
Establish a secure, scalable cloud-based mainframe architecture using the IBM zOS.
Segment networks and air-gap sensitive systems for layered protection.
Protect patient privacy, ensure compliance, and prevent unauthorized disclosure of ePHI.
Implement the principles of the CIA Triad from conception by embedding all three pillars in network architecture, policy design, and incident response strategies.

Maintaining confidentiality through:

- Role Based Access Control (RBAC)
- Multi-Factor Authentication (MFA)
- Data minimization and anonymization
- Employee training
- Network segmentation
- Real-time continuous monitoring and threat detection
- VPN-secured communication between the cloud mainframe and facilities
- Access revocation for deactivated accounts
- Deploy API gateways with encryption

Maintaining integrity through:

- Cryptographic hashing
- Encryption of all ePHI in transit and at rest
- Audits
- Secure backups to detect and recover from tampering
- Detailed logs to account for any illegitimate access, change, or deletion of data
- Patch management

Maintaining availability through:

- Redundant systems and frequent data backups
- Testing of disaster recovery procedures
- Cloud based architecture for scalability
- Simulated outage drills

Evaluation

- Perform quarterly internal security testing
- Conduct annual third-party audits
- Simulate outages, breaches, and recoveries to validate effectiveness of safeguards
- Continuous system updates aligned with HIPAA and cybersecurity best practices

2.8. PRIVACY REGULATIONS

Legal Basis for Protection and Privacy

- HIPAA is the primary U.S. law protecting ePHI
    - HIPAA violations can lead to civil and criminal penalties
    - The HIPAA Privacy Rule grants patients' rights over their health information
    - The HIPAA Security Rule requires administrative, technical, and physical safeguards
- Legal responsibilities include data minimization, proper disclosures, and breach notifications

HIPAA Compliance

- Maintain patient consent documentation
- Enforce safeguards such as encryption and audit logging
- Notify individuals, HHS, and media (if required) after a breach
- Maintain incident response protocols and breach documentation
- Systems and policies are reviewed regularly to ensure compliance
- ePHI access is limited through RBAC

Ongoing Training & Awareness

- Regular HIPAA compliance training for staff
- Simulated phishing and breach events to strengthen security posture
- Adherence to:
    - Data retention policies
    - Encryption at rest and in transit
    - Data anonymization and minimization practices

Reference

Ang, A. (2023, March 29). Fujitsu launches new cloud-based health data platform. Healthcare IT News. https://www.healthcareitnews.com/news/asia/fujitsu-launches-new-cloud-based-health-data-platform